

AI CYBERSECURITY GUIDE

Full Professional Version — Threat Landscape, Protection, and Response

Document Type: Security awareness + practical protection playbook

Audience: All organization members; IT and security staff

Version: 2.0 · Last Updated: May 2026

Estimated Read Time: 60 minutes

Table of Contents

1. AI Security Landscape
2. Deep Dive: The Top 5 AI Threats
3. Three More Threats You'll See in 2026
4. Practical Protection Strategies
5. Compliance & Regulatory Mapping
6. Vendor Security Evaluation
7. Incident Response Playbook
8. Staff Training Recommendations
9. Quick Reference Card

1. AI Security Landscape

AI systems introduce a security model that overlaps with traditional cybersecurity but is meaningfully different. Where a traditional vulnerability is typically an exploit against a fixed system, AI vulnerabilities are often emergent: they arise from the interaction between the model, its inputs, and the data it was trained on. Defending an AI system requires layering on top of your existing security stack — not replacing it.

1.1 How AI changes the threat model

- **The input becomes an attack surface.** User-supplied text can manipulate model behavior (prompt injection).
- **The model itself is a liability.** Models memorize. They can leak training data when prompted carefully.
- **Data flows multiply.** Every prompt sent to a cloud AI service is a potential data exfiltration channel.
- **Trust boundaries dissolve.** AI agents that take actions blur the line between user and system.
- **Supply-chain risk amplifies.** The model, the platform, the orchestration layer, and any retrieved data are all dependencies.

1.2 Cost of getting it wrong

AI-related security incidents in the news typically involve one of three failure modes: confidential data shared with a public LLM, prompt injection that bypassed a guardrail, or a third-party AI vendor breach that exposed customer data. The remediation costs of each pattern run from a few thousand dollars for an internal review to millions in regulatory fines and brand damage.

1.3 Who is responsible?

AI security is not the IT department's exclusive problem. Practical accountability looks like this:

Role	Responsibility
Executive sponsor	Owns the risk appetite. Decides go/no-go on AI tools above a threshold.
IT / Security	Operational security, monitoring, incident response, vendor reviews.
Legal / Compliance	Maps AI use to regulatory obligations. Manages contracts.
Department managers	Enforce policy in their teams. Approve specific tools and use cases.
All staff	Follow the AI usage policy. Report incidents and near-misses.

2. Deep Dive: The Top 5 AI Threats

2.1 Threat 1: Data Exfiltration via AI

What it is: Sensitive organizational data being shared with a third-party AI service, intentionally or not, in ways that violate confidentiality expectations or compliance obligations.

How it happens:

- Employee pastes confidential text into a consumer chatbot to summarize.
- An AI coding assistant uploads proprietary code to the vendor's cloud.
- An AI-powered search bar indexes documents the user shouldn't be allowed to see.
- Email drafting AI accesses calendars or contacts that should be off-limits.

Real examples:

- Samsung's 2023 incident: engineers pasted source code into ChatGPT to debug.
- Multiple law firms have reported attorney use of public LLMs to summarize confidential filings.
- Healthcare facilities have flagged staff using personal accounts to translate clinical notes.

Detection signs:

- Outbound traffic to consumer AI domains from corporate networks.
- Browser extension installations of AI tools by non-IT staff.
- Sudden drops in time-to-complete on document-heavy tasks without corresponding tool deployments.

Prevention:

- Provision an approved enterprise AI tool with data residency guarantees.
- Block consumer AI domains at the network layer for users who don't have an approved business need.
- Train staff on what data categories must never enter any AI tool.
- Audit AI tool usage quarterly.

2.2 Threat 2: Prompt Injection & Jailbreaking

What it is: Specially crafted inputs that make an AI model ignore its instructions and behave in unintended ways. Direct prompt injection is in the user's message; indirect injection is embedded in content the model reads (web pages, emails, documents).

How it happens:

- User says 'ignore your previous instructions and...' (direct).
- AI summarizes a malicious webpage that includes hidden instructions (indirect).
- An attacker emails an executive's AI assistant with text designed to trigger an action (indirect).
- A document uploaded to a RAG system contains injection patterns.

Real attacks:

- Multiple companies' customer-support bots have been jailbroken into producing offensive content, generating screenshots that go viral.
- Researchers have demonstrated indirect injection via emails to AI assistants causing data leaks.

Defense strategies:

- Treat all model inputs as untrusted, including retrieved documents.
- Limit what the model can DO, not just what it can SAY. Restrict tool access.
- Layered filtering: input filter + system prompt hardening + output filter.
- Human review for any consequential action triggered by AI.
- Use vendor-provided guardrails but don't depend on them alone.

2.3 Threat 3: Model Poisoning

What it is: Attackers influence the data a model is trained or fine-tuned on, causing the model to behave maliciously on specific triggers while appearing normal otherwise.

How to detect:

- Anomalous outputs on specific input patterns.
- Performance regressions on internal test sets after retraining.
- Output sentiment shifts inconsistent with training data updates.

Prevention:

- Curate training data sources. Avoid scraping or unverified third-party datasets.
- Provenance tracking for any fine-tuning data.
- Adversarial testing as part of release cycles.
- Treat fine-tuning data as you would production code: code review, version control, access controls.

2.4 Threat 4: Privacy Attacks (Re-identification, Membership Inference, Model Inversion)

What it is: Adversaries extract information about training data — sometimes individual records — by querying the model in targeted ways.

- **Membership inference:** determining whether a specific record was in the training set.
- **Model inversion:** reconstructing training data from model behavior.
- **Re-identification:** linking 'anonymous' outputs back to individuals.

Defenses:

- Differential privacy during training where feasible.
- Output filtering for personally identifying patterns.
- Rate limiting and query auditing.

- Don't train on data that wouldn't be safe to release.

2.5 Threat 5: Third-Party Vendor Compromise

What it is: A breach at your AI vendor exposes your data, even though your own systems were intact.

- Vendor evaluation: don't accept self-attestation. Require independent audit reports.
- Contractual breach notification SLAs.
- Minimize data shared with each vendor.
- Monitor vendor security posture continuously, not just at procurement.
- Have a documented response plan for vendor-side incidents.

3. Three More Threats You'll See in 2026

3.1 AI-generated phishing at scale

LLMs make spear-phishing trivial. Personalized, grammatically perfect, contextually accurate phishing emails are now mass-produced. Your awareness training built on 'look for typos' is obsolete.

- Update phishing training: focus on out-of-band verification, not on spotting bad grammar.
- Tighten financial wire-transfer authorization workflows.
- Voice cloning is a credible threat for executive impersonation calls.

3.2 Autonomous agent abuse

As AI agents take more actions (calendar, email, browser, code execution), they create a new lateral-movement surface.

- Limit agent tool permissions to least-privilege.
- Require approval for high-impact actions (financial, deletion, external comms).
- Audit agent action logs the same way you audit privileged user actions.

3.3 Deepfake-based social engineering

Video and voice deepfakes are good enough now to fool casual verification. The Hong Kong \$25M Arup case (an employee was tricked by a deepfaked Zoom call of his CFO) is the canonical example.

- Establish a verbal code-word system for high-value transactions.
- Require multi-channel verification (e.g., known phone line, not just video).
- Make it culturally acceptable to pause and double-check executives.

4. Practical Protection Strategies

4.1 Data classification first

You cannot protect what you have not classified. The simplest workable scheme:

Classification	Examples	AI-tool rule
Public	Marketing copy, press releases	Any AI tool
Internal	Project plans, training materials	Approved enterprise AI only
Confidential	Customer data, contracts	Approved enterprise AI with logging
Restricted	PHI, PII, financial records	No AI without legal review

4.2 Access controls

- Treat enterprise AI accounts as privileged accounts: SSO, MFA, periodic access review.
- Provision a per-user identity for AI tools — no shared accounts.
- Limit which data sources each AI tool can connect to.
- Use role-based access for AI agents (HR agent doesn't see Engineering tickets).

4.3 Logging and monitoring

- Log all prompts and responses for at least 90 days.
- Set up alerts on PII patterns in prompts and responses.
- Review logs for emerging risky patterns monthly.
- Ensure logs themselves are protected — they are sensitive.

4.4 What NOT to do

- Don't ban AI outright. People will use it anyway, off the books.
- Don't rely on a single vendor guardrail. Defense in depth.
- Don't assume your DLP catches AI exfiltration. It probably doesn't.
- Don't skip incident response planning because 'we don't have AI yet'. You have shadow AI already.

4.5 What TO do

- Pick one approved enterprise AI for the org. Make it the path of least resistance.
- Publish a short, plain-language AI usage policy.
- Train every staff member on the policy in under 30 minutes.
- Establish a no-blame reporting channel for AI mistakes.
- Conduct a quarterly review of AI tools in use.

5. Compliance & Regulatory Mapping

5.1 GDPR

- Data subject rights apply to AI training data and outputs.
- Conduct DPIA before deploying AI that processes personal data at scale.
- Right to explanation may apply to automated decisions.
- Breach notification: 72-hour clock applies.

5.2 HIPAA

- PHI must not be shared with AI services without a BAA.
- Even with a BAA, document specific safeguards.
- Patient-facing AI chatbots have specific risk profiles.
- Audit controls apply to AI access to PHI.

5.3 FERPA

- Student records cannot be shared with AI tools that train on the data.
- Parental consent rules may apply.
- Particularly relevant for K-12 use of consumer AI.

5.4 CCPA, state privacy laws, and industry rules

- Disclose AI use in privacy notices.
- Honor opt-out requests for automated decisions.
- Maintain inventory of AI uses for compliance reporting.
- Industry overlays: PCI-DSS for cardholder data, FISMA / 800-53 for federal contractors, NERC CIP for utilities.

6. Vendor Security Evaluation

Use this checklist when evaluating any AI vendor. Items not in scope should be explicitly noted.

6.1 Due diligence checklist

- SOC 2 Type II or ISO 27001 report within last 18 months.
- Data flow diagram from vendor.
- List of subprocessors.
- Data residency commitments.
- Encryption practices (at rest, in transit, key management).
- Incident response plan and historical incident reports.
- Privacy impact assessments for relevant frameworks.
- Penetration testing summary.
- Vulnerability disclosure program.

6.2 Questions to ask

- How is our data isolated from other customers?
- Will our data be used to train your models? Under what conditions?
- How are model updates rolled out? Can we test before adoption?
- What guardrails exist against prompt injection?
- What does your shared responsibility model look like?
- What happens to our data on termination?

6.3 Red flags

- Refusal to provide audit reports under NDA.
- Vague language about training data usage.
- No named security contact.
- Compliance certifications cited but not produced.
- Pricing model that punishes you for security questions.

7. Incident Response Playbook

7.1 Detection

- Define what 'an AI incident' is in plain language for your org.
- Centralize reporting (one channel: email, Slack, ticket queue).
- Triage criteria: confirmed data exposure → high; suspicious AI behavior → medium; tool misuse → low.

7.2 Response — first 4 hours

- 1 Confirm the incident: what happened, what data is involved, who knows.
- 2 Contain: pause access to the affected tool, lock affected accounts.
- 3 Notify: legal, security, executive sponsor.
- 4 Preserve: logs, prompts, responses, screenshots.
- 5 Document: who did what, when.

7.3 Response — first 72 hours

- Determine notification obligations (GDPR 72h, HIPAA 60d, state laws vary).
- Engage vendor if it's a vendor-side incident.
- Customer/citizen notification if PII/PHI is affected.
- Begin root cause analysis.

7.4 Post-incident review

- Within 30 days: written post-mortem.
- Identify policy or training gaps. Update them.
- Share lessons learned org-wide without blame.
- Update detection rules based on what was missed.

8. Staff Training Recommendations

8.1 Minimum required content for all staff

- What data categories must never enter any AI tool.
- Which AI tools are approved for which data categories.
- How to report an AI mistake or near-miss.
- What to do if you accidentally shared confidential info with an AI.
- Phishing patterns: AI-generated emails, voice clones, deepfakes.

8.2 Additional content for power users

- Prompt injection recognition and reporting.
- Data classification before AI use.
- Reviewing AI-generated content before sending externally.
- Tool-specific security features (data export, retention settings).

8.3 Reinforcement

- Tabletop exercises annually for IT/security.
- Quarterly reminders for general staff.
- Onboarding includes AI policy module.
- Reward reporting; never punish near-misses.

9. Quick Reference Card

PRINT THIS PAGE

Pin to your desk. Or print on the back of your badge.

Never share with public AI tools:

- Customer or client PII
- Health information (PHI)
- Financial records, account numbers
- Source code, proprietary algorithms
- Confidential strategy documents
- Personnel information
- Vendor contracts

Always do before using AI:

- Classify the data: is this OK for this tool?
- Verify the tool is on the approved list.
- Review AI output before sending externally.
- Log unusual outputs and report.

Report immediately to security@yourorg.com:

- Sensitive data shared with AI by accident.
- AI output that doesn't look right.
- Phishing emails that look unusually personalized.
- Voice calls that don't seem quite right.

About AI Impact Maine

AI Impact Maine helps Maine businesses, municipalities, and nonprofits assess, plan, and responsibly implement AI. We offer readiness assessments, training programs, policy and governance design, vendor evaluation, and ongoing strategic support.

Get in touch

Email: ahmad@aiimpactmaine.com

Web: aiimpactmaine.com

Book a free 30-minute consultation: aiimpactmaine.com/contact